INTRODUCTION TO INFORMATION SECURITY & SECURE DEVELOPMENT

SECURE WEB DEVELOPMENT

Outline

- Definitions
- Key Concepts
- Software Engineering
- Model-View-Controller Architecture

1 Attack Volume

App attacks hit 83% in early 2025 (up from 65% in 2024), with Layer 7 DDoS attacks showing massive growth (94% quarterly increase between 2023-2024).

https://digital.ai/resource-center/whitepapers/2025-application-security-threat-report/

2 Top Vulnerabilities (OWASP 2025)

Broken Access Control remains #1; Security Misconfiguration rose to #2; Software Supply Chain Failures is a new critical risk (#3).

https://owasp.org/Top10/2025/0x00_2025-Introduction/

3 AI's Role

93% of leaders expect daily AI-based attacks, with AI boosting phishing (82% of incidents), ransomware, and bot attacks.

https://zerothreat.ai/blog/cybersecurity-statistics-and-facts

4 Open-Source Risk

86% of audited apps had open-source vulnerabilities, with 81% containing high/critical issues and 91% using outdated components.

https://www.opentext.com/en/media/white-paper/state-of-application-security-trends-challenges-and-upcoming-threats-wp-en.pdf

5 Budget & Visibility

Global cybersecurity spending to grow 15% in 2025; yet, many organizations (75%) reported SaaS security incidents despite feeling secure.

https://appomni.com/reports/state-of-saas-security/

6 Human Element

The human factor remains central, involved in 68% of breaches, and phishing breaches take over 200 days to detect.

https://www.verizon.com/business/resources/reports/dbir/

DEFINITIONS

What is Information?

"Information is an asset
to all individuals & businesses."

What is Information Security?

It refers to "the protection of assets (information) in order to achieve CIA (Confidentiality, Integrity, and Availability)."

—InfoSec HK

What is Information Security?

It refers to "the processes and methodologies which are designed and implemented to protect print, electronic, or any other form of confidential, private, and sensitive information or data from unauthorized access, use, misuse, disclosure, destruction, modification, or disruption."

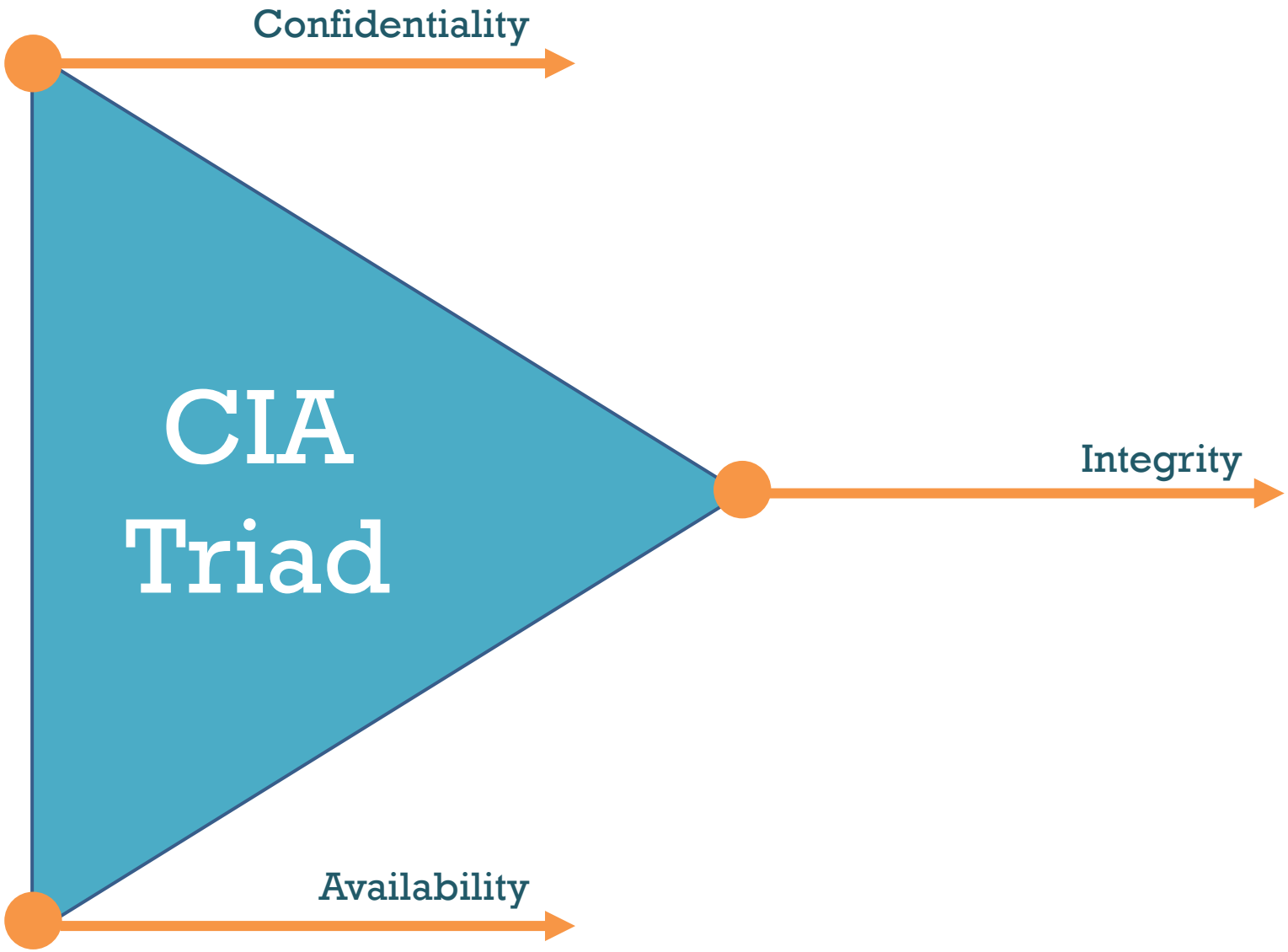
—SANS (SysAdmin, Audit, Network, and Security) Institute

What is Information Security?

"Involves the study of not only more detailed mathematical designs of cryptographic, communication, transport, and exchange protocols and best practices but also, the state of both data and information in motion and in storage (at rest)."

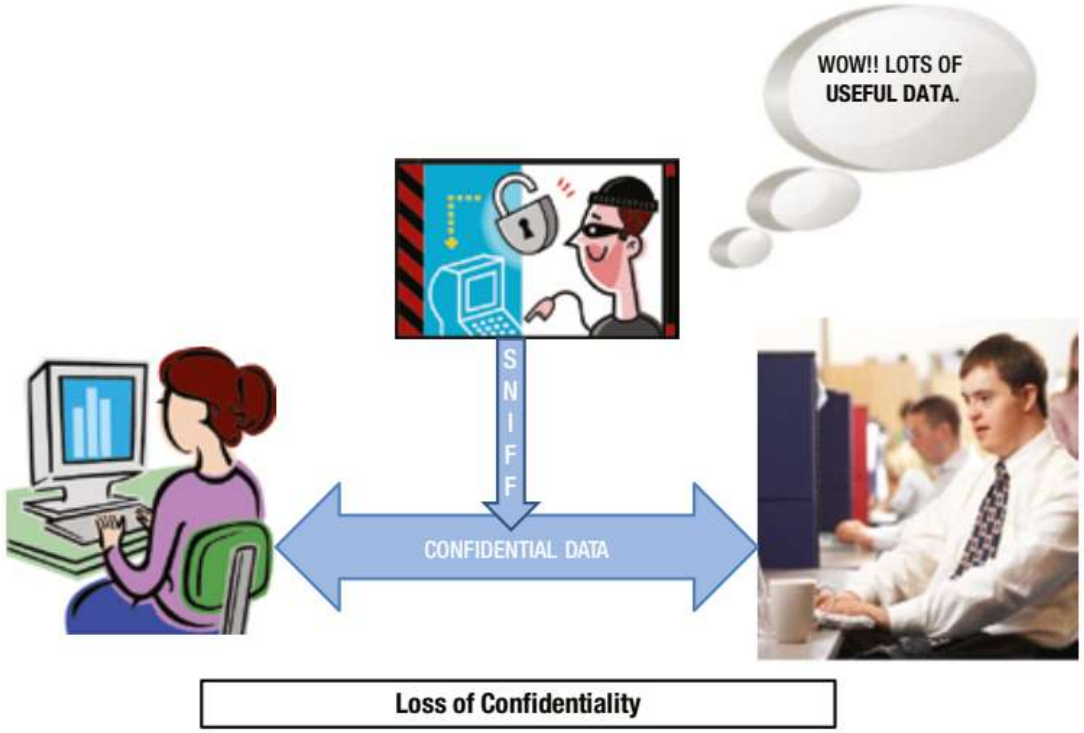
—Kizza (2013)

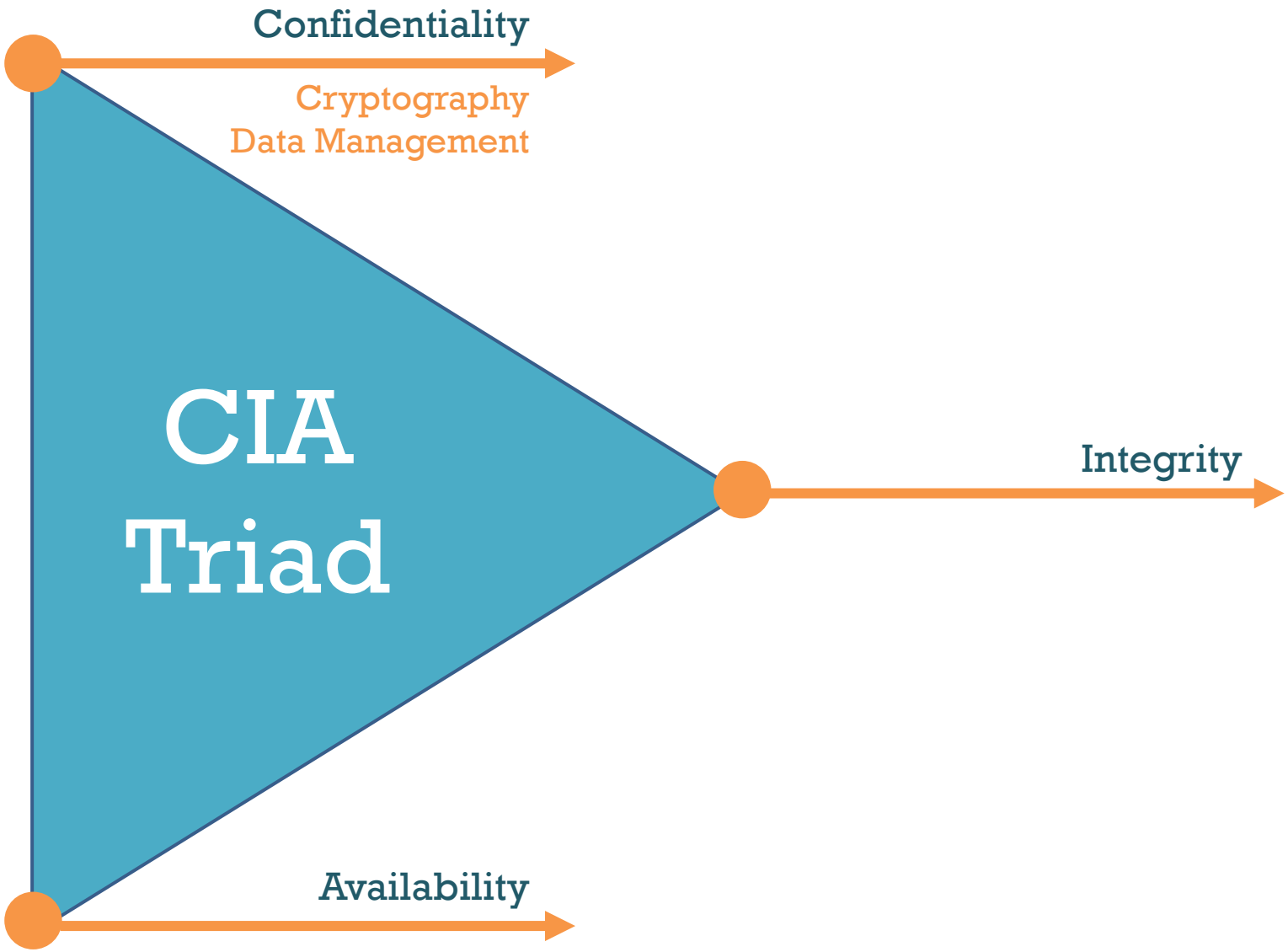
KEY CONCEPTS


Confidentiality
CIA
Triad
Integrity
Availability

Confidentiality

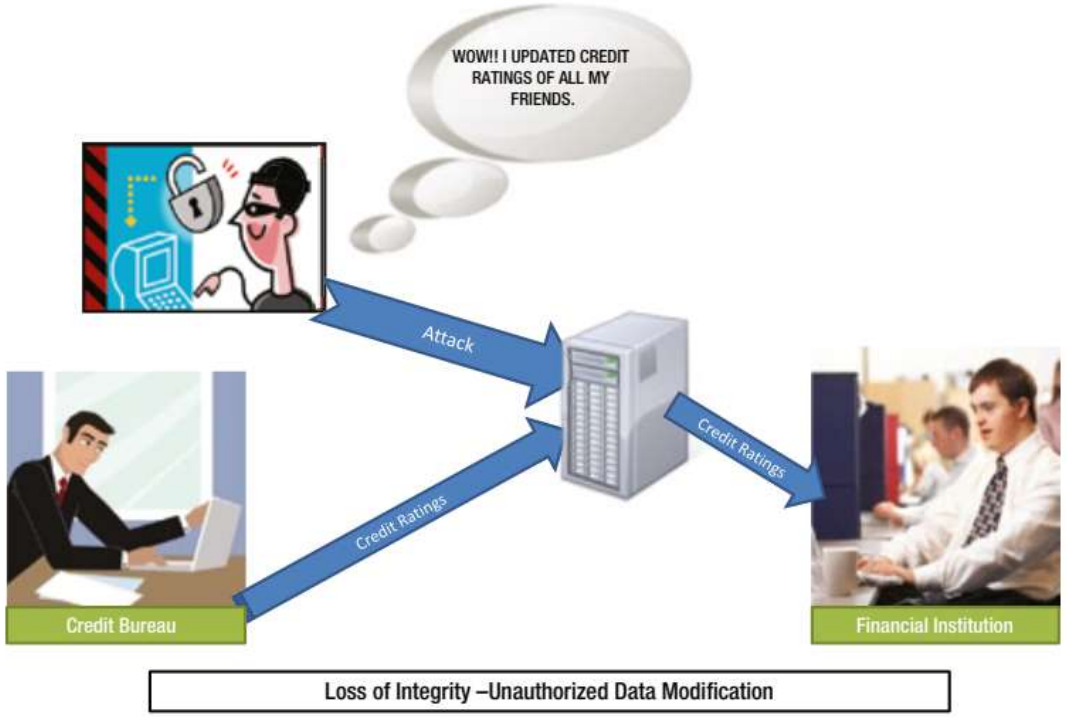
- The state in which data is only disclosed to authorized subjects.
- Example:
  - When submitted to a website, your personal data should only be used or accessed exclusively by designated staff in that company for the purposes agreed.
  - No one else should be allowed to use your data for illegal purposes, or view the data out of curiosity.

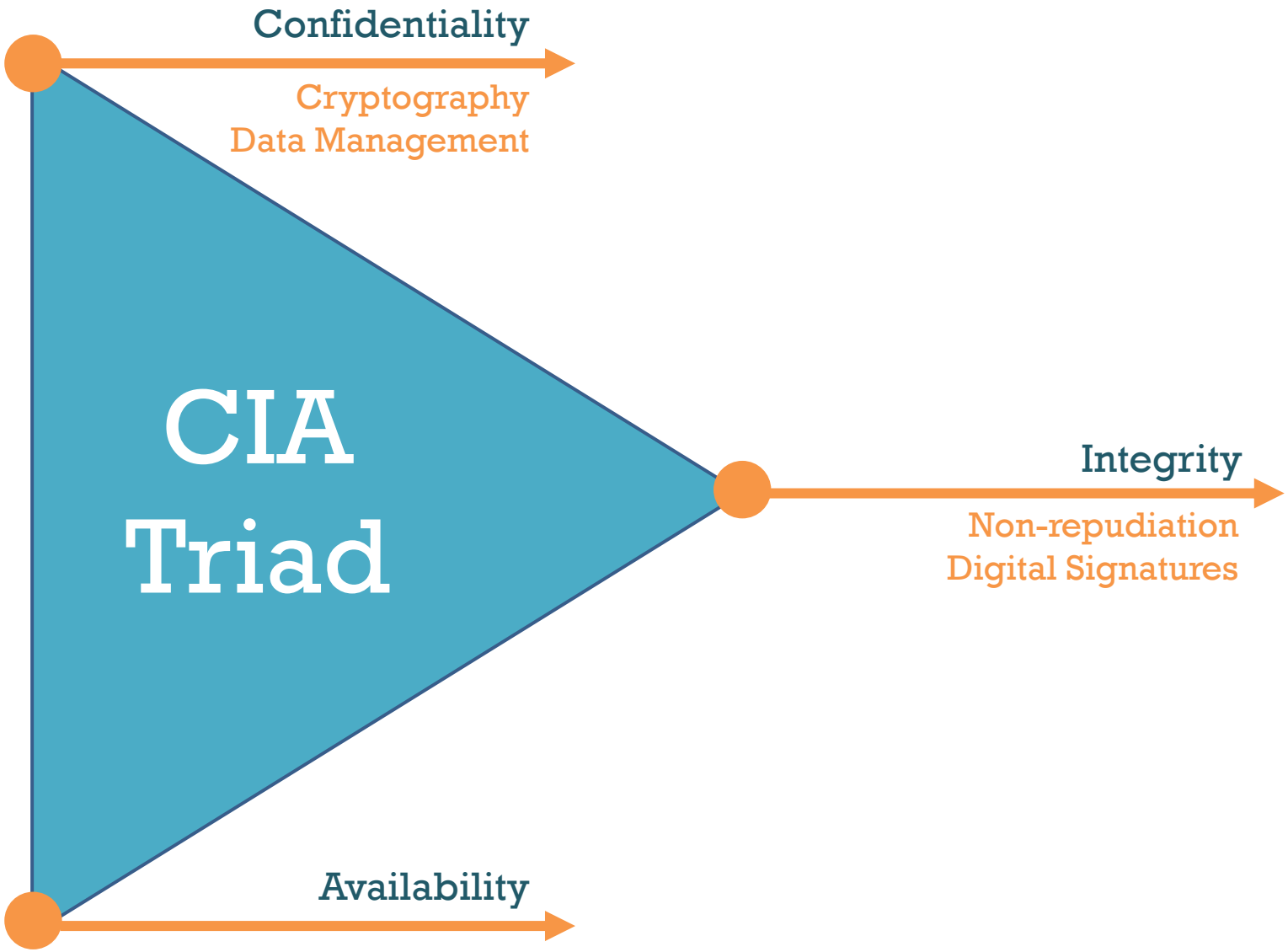



Confidentiality
Cryptography
Data Management
CIA
Triad
Integrity
Availability

Integrity

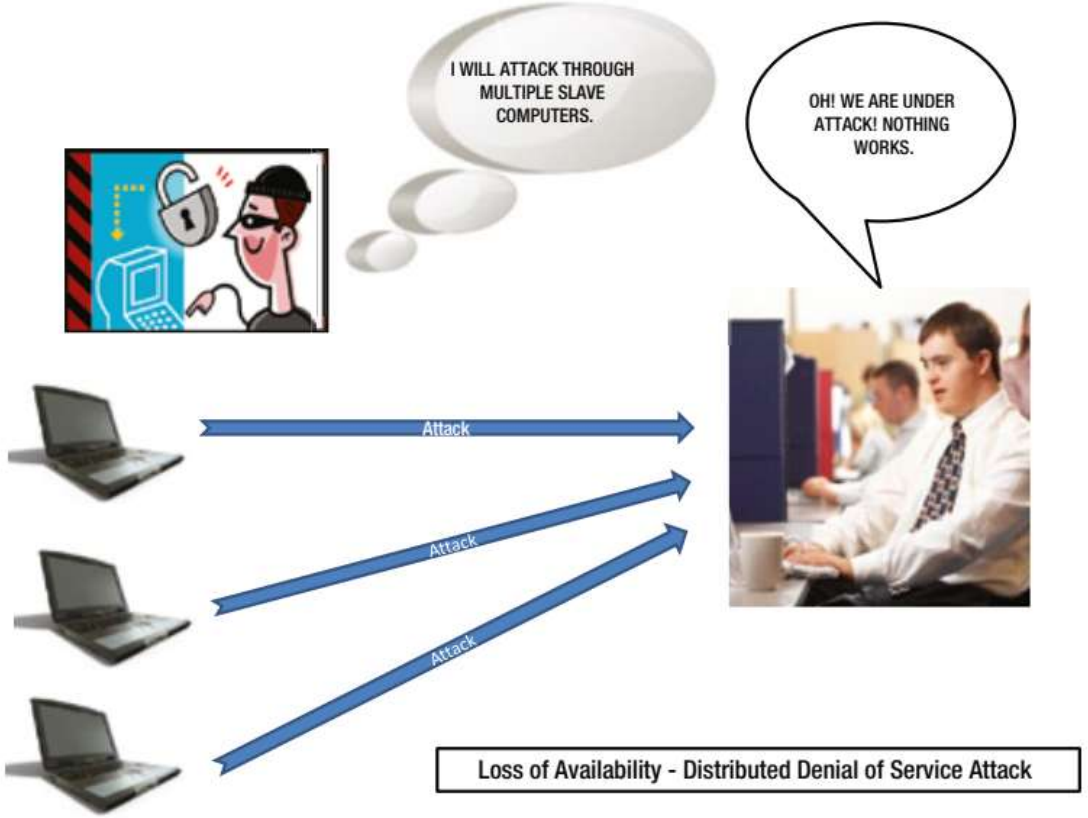
- The state in which data is not modified/deleted without prior authorization.
- Example:
  - When submitted to a website, your personal data should not be altered in any way during data transmission, or by the website company.

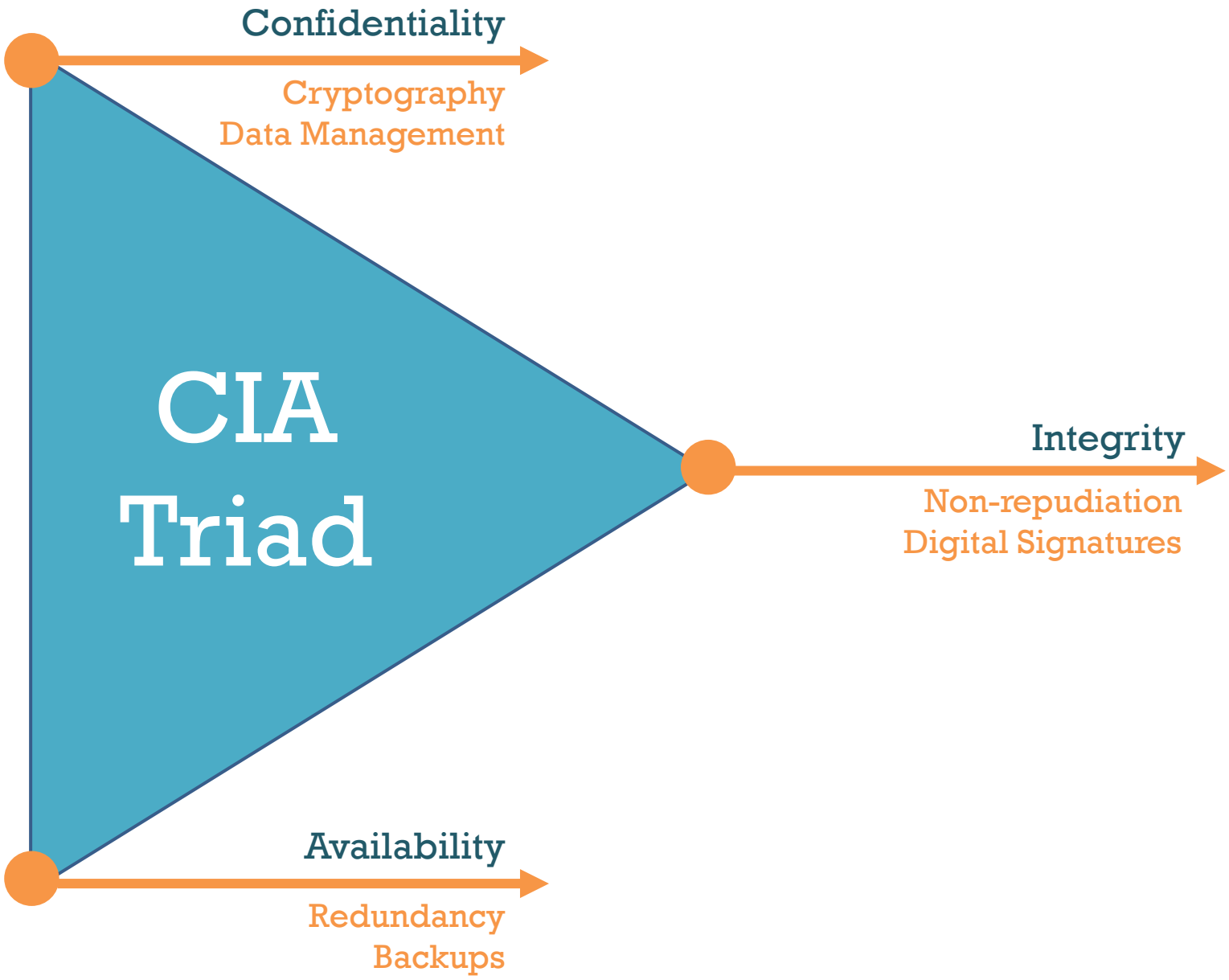



Confidentiality
Cryptography
Data Management
CIA
Triad
Integrity
Non-repudiation
Digital Signatures
Availability

Availability

- The state in which assets are made available in a timely manner to authorized subjects.
- Example:
  - You should be able to access and check your personal data kept on a website at any time.




Confidentiality
Cryptography
Data Management
CIA
Triad
Integrity
Non-repudiation
Digital Signatures
Availability
Redundancy
Backups

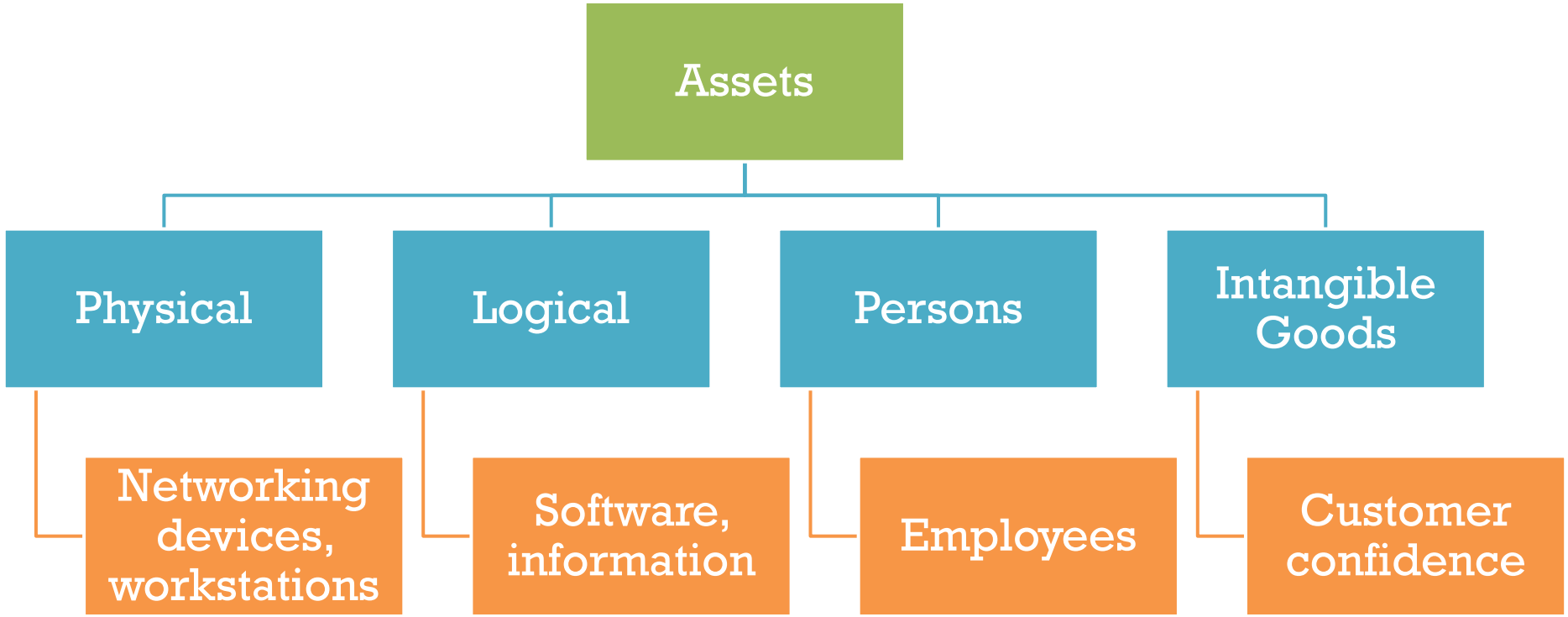
CIA Triad: Core Objectives of Information Security

Objective	Focus	Example Failure
Confidentiality	Who can access data	Data leakage
Integrity	Accuracy of data	Data tampering
Availability	Access when needed	System downtime

Security
Asset
Threat
Threat Agent
Vulnerability
Attack
Impact
Likelihood
Risk
Control

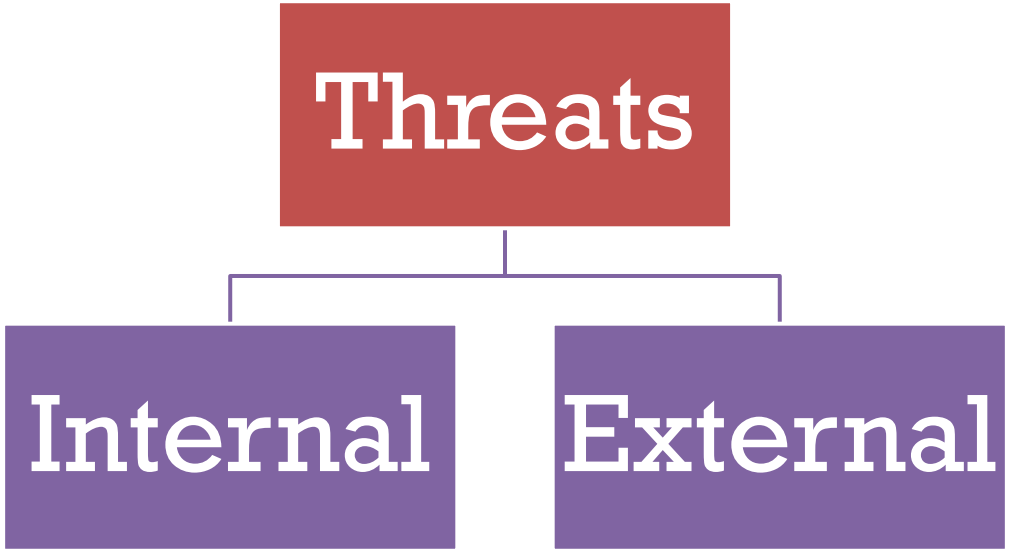
Asset

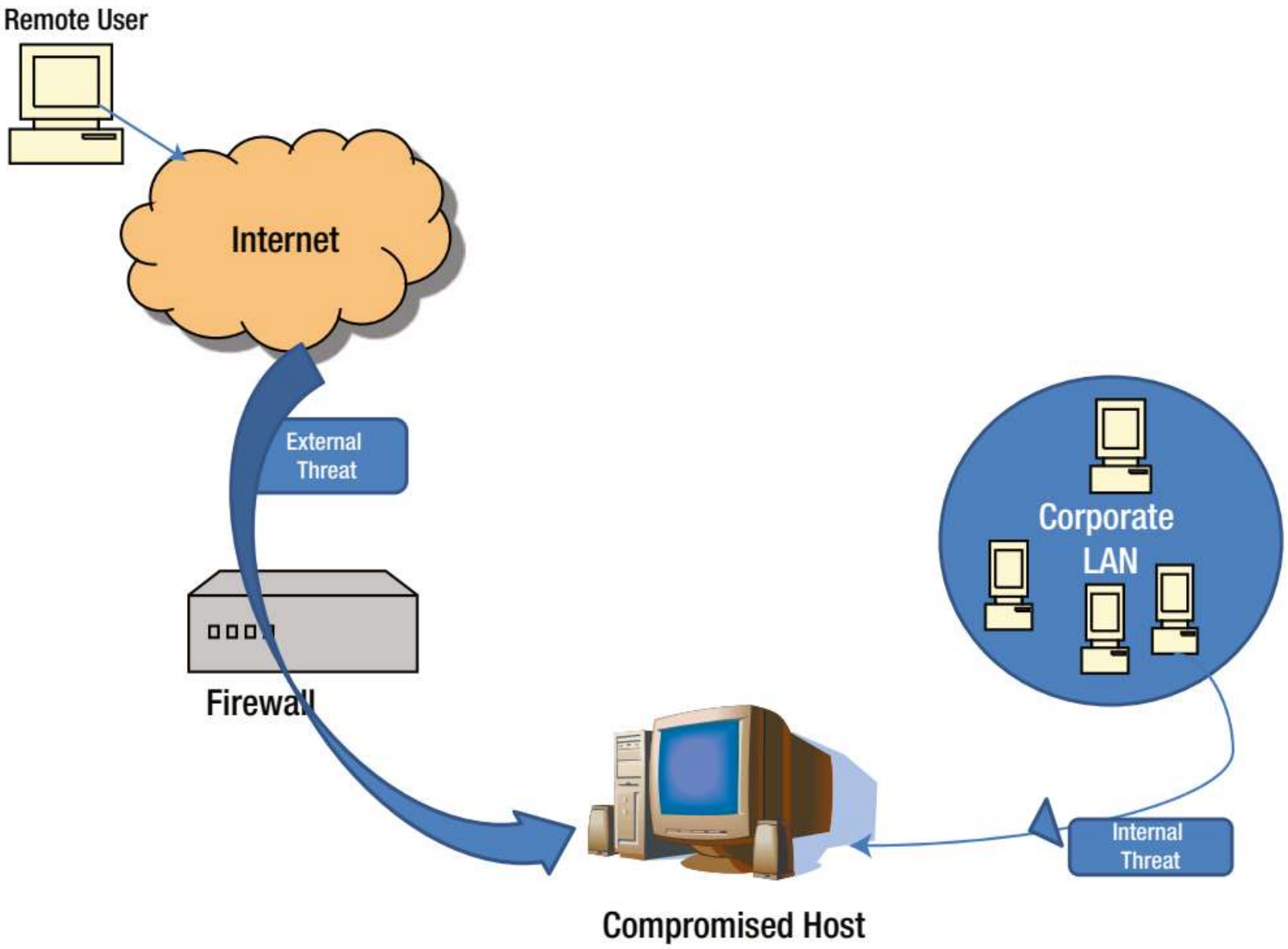
Any item, tangible or intangible, with value to an individual or organization.



Threat

- A threat is what can go wrong because of the exploitation of vulnerabilities or attack on the assets, such as data theft or unauthorized modification of the data.
- Combination of asset + vulnerability




Remote User
Internet
External Threat
Firewall
Corporate LAN
Internal Threat
Compromised Host

THREAT AGENT

An individual or group that is capable of carrying out a particular threat.

Vulnerability

- An inherent weakness in a network or network device.
- It could be hardware or software or both.

Relationship Between Asset, Threat, and Vulnerability

- Asset: Something of value that must be protected
- Vulnerability: A weakness in the asset or system
- Threat: A potential danger that exploits a vulnerability

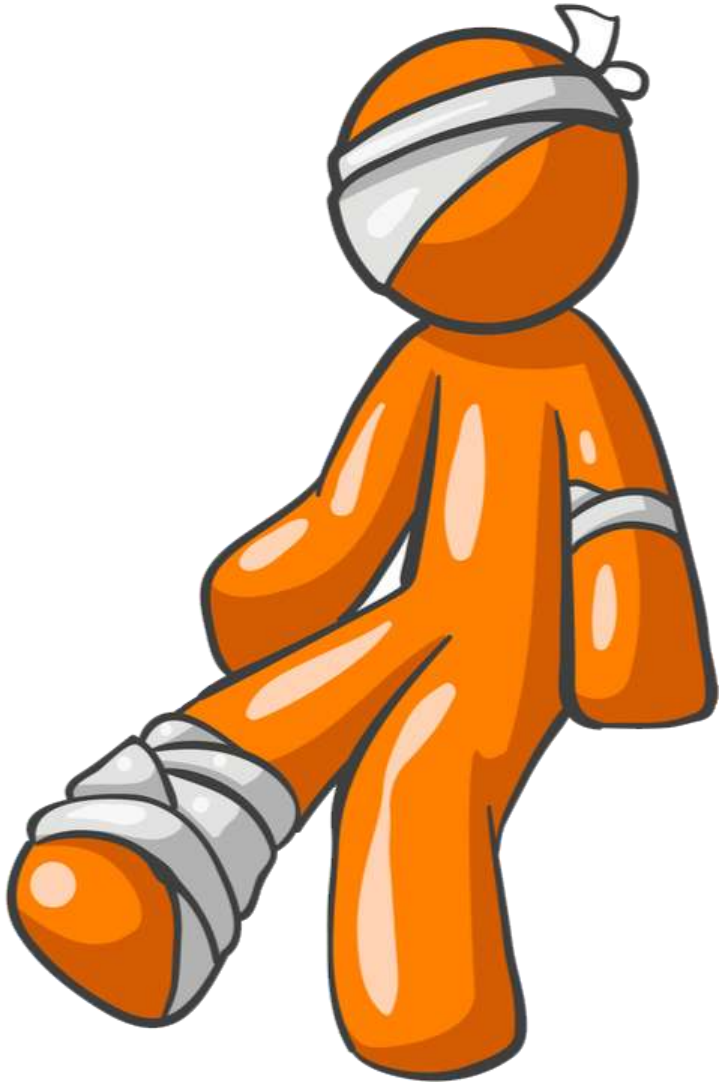
Attack

- An unauthorized action with the intent to cause damage, or hinder or breach the security of a network.
- An attack is launched by intruders to damage the network and network resources such as endpoint devices, servers, or desktops which are vulnerable.

Threat vs Threat Agent vs Attack

Term	Definition	Example
Threat	Potential cause of harm	Malware
Threat Agent	Entity causing the threat	hacker
Attack	Actual exploitation	SQL injection

Remember: A threat does not always result in an attack.



IMPACT

A measure of the potential damage caused by a particular threat.

Likelihood

- A measure of the possibility of a threat being carried out.
- A variety of factors can affect the likelihood of a threat being carried out, including how difficult the implementation of the threat is, and how rewarding it would be to the attacker.

What is the *likelihood* that it will rain?

Risk

The probability that a particular threat directed towards a specific vulnerability will occur.

What is the *likelihood* that it will rain?

What is the *risk* of you getting wet when you go outside?

Risk, Likelihood, and Impact

- Likelihood: Probability that a threat will occur
- Impact: Damage caused if the threat occurs
- Risk: Combined effect of likelihood and impact

$$\text{Risk} = \text{Likelihood} \times \text{Impact}$$

Control

Safeguard or countermeasure that you put in place in order to avoid, detect, counteract, or minimize potential threats against your information, systems, or other assets.

TYPES OF SECURITY CONTROLS	CONTROL FUNCTIONS		
	PREVENTATIVE	DETECTIVE	CORRECTIVE
PHYSICAL CONTROLS	• Fences • Gates • Locks	• CCTV • Surveillance Cameras	• Repair physical damage • Re-issue access cards
TECHNICAL CONTROLS	• Firewall • IPS • MFA • Antivirus	• IDS • Honeypots	• Vulnerability patching • Reboot a system • Quarantine a virus
ADMINISTRATIVE CONTROLS	• Hiring & termination policies • Separation of duties • Data classification	• Review access rights • Audit logs and unauthorized changes	• Implement a business continuity plan • Have an incident response plan

https://purplesec.us/learn/security-controls/

SOFTWARE ENGINEERING

Software Engineering

The process of solving customers' problems by the systematic development and evolution of large, high-quality software systems within cost, time and other constraints.

Software Engineering

Challenges

- Lack of understanding of user needs
- Unclear scope
- Lack of change management
- Poor project planning
- Communication problems
- Teamwork problems
- Security issues

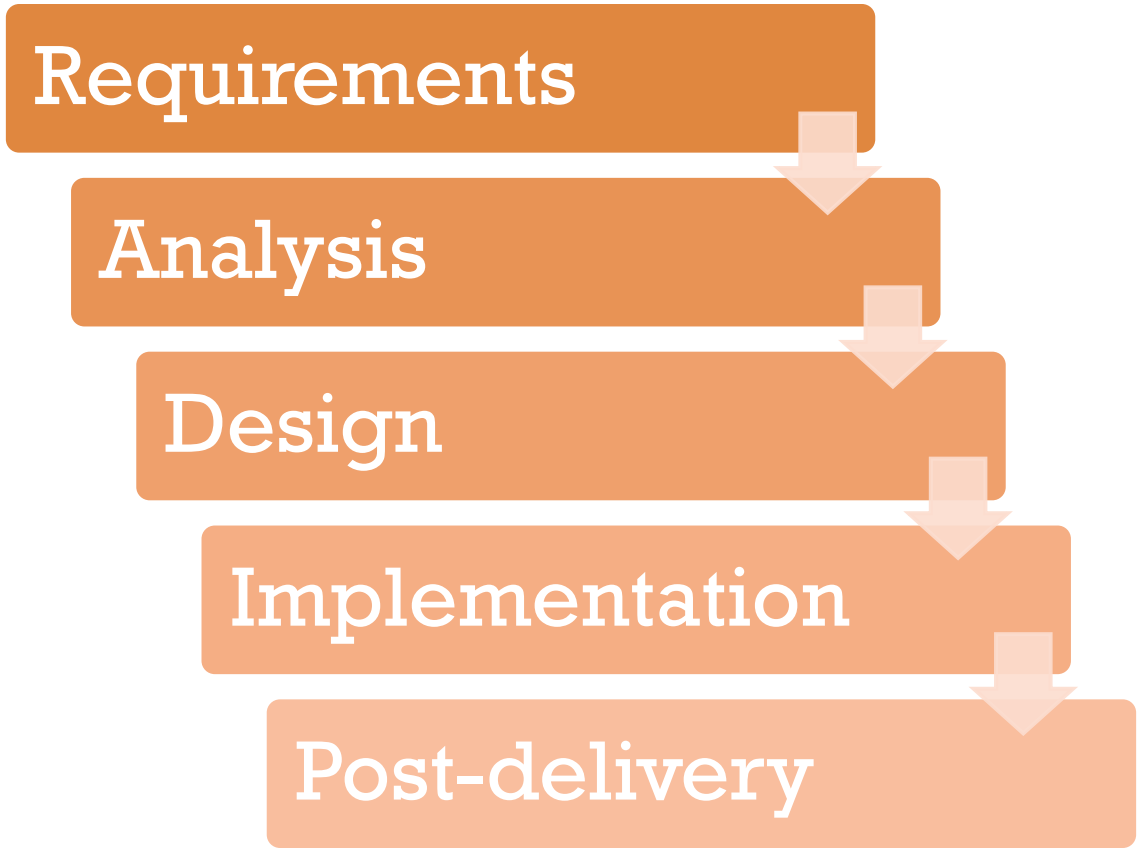
Software Development

A sequence of steps that are performed when building software products

Sequences/steps vary depending on model

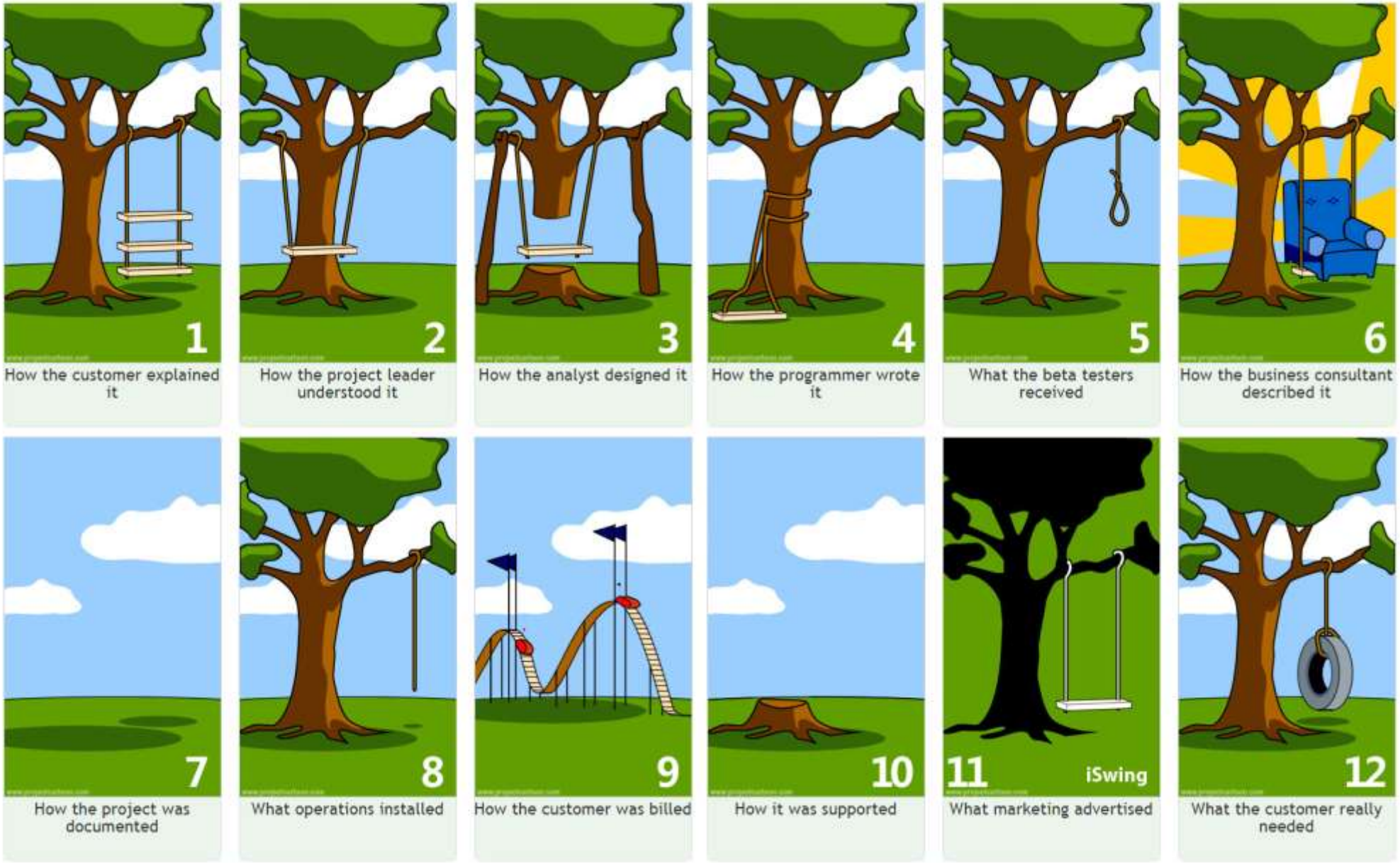
Life cycles have evolved over time in response to changing technology and user needs

Basic SDLC Phases



SDLC Models

Code-and-Fix	Waterfall	Iterative
Incremental	Agile	Scrum



https://cdn.zsite.net/us1/upload/201712/f_2a1ca764ce384a33d056f8256f6a1ce5.jpg

MODEL-VIEW-CONTROLLER ARCHITECTURE

Model-View-Controller

A software architecture ideally suited to web applications

Separates the logic from the user interface

Allows individual components to be tested independently of one another

In terms of security, provides an extra layer of protection through isolation

View

Model

```
int xPosition = 50;
int yPosition = 50;
double opacity = 0.35;
Font font = new Font("Arial",
    Font.BOLD, 24)
String text = "Some Transparent
    Text";
```

Controller

```
public void changeXPosition(int newXPosition);
public void changeYPosition(int newYPosition);
public void changeOpacity(double newOpacity);
public void changeFont(Font newFont);
public void changeText(String newText);
```

Model

- Encapsulates functionality and represents data in a structured manner
- Provides an abstraction between low level primitives and the Controller and View
- At this level, data being received and sent should be checked against business rules in place

Encapsulates application state

Responds to state queries

Exposes application functionality

Notifies views of changes

View

- Also called the presentation layer, the view provides users a front end with which to interact with
- This level renders data into HTML and should not contain any business logic
- Data collected from this is sent back to the Controller

Renders the models

Requests updates from models

Sends user gestures to controller

Allows controller to select view

Controller

- Contains the application or business logic needed to process user data
- This acts as the mediator between the Model and the View
- Apart from processing, it should contain code needed to protect the application from threats

Defines application behavior

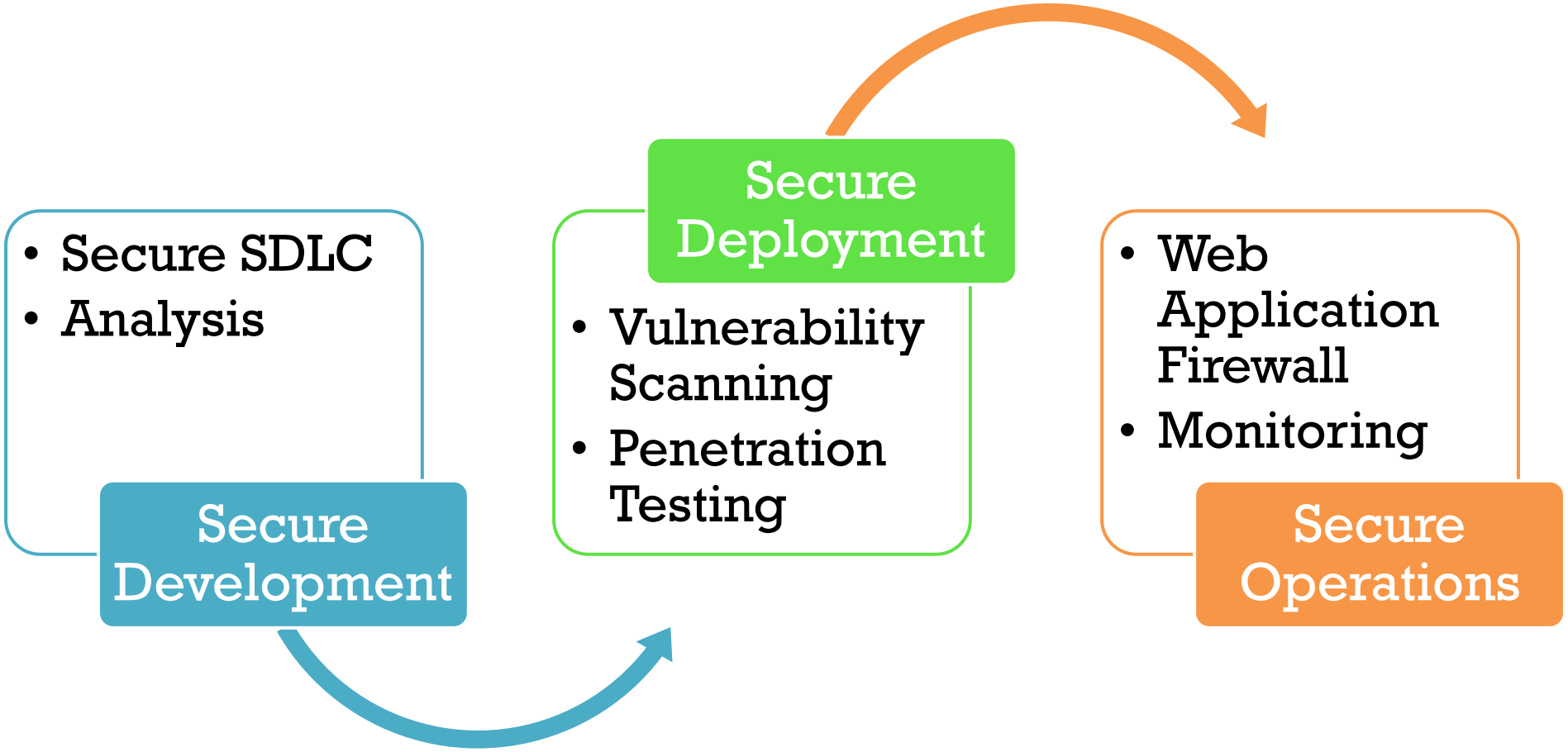
Maps user actions to model updates

Selects view for response

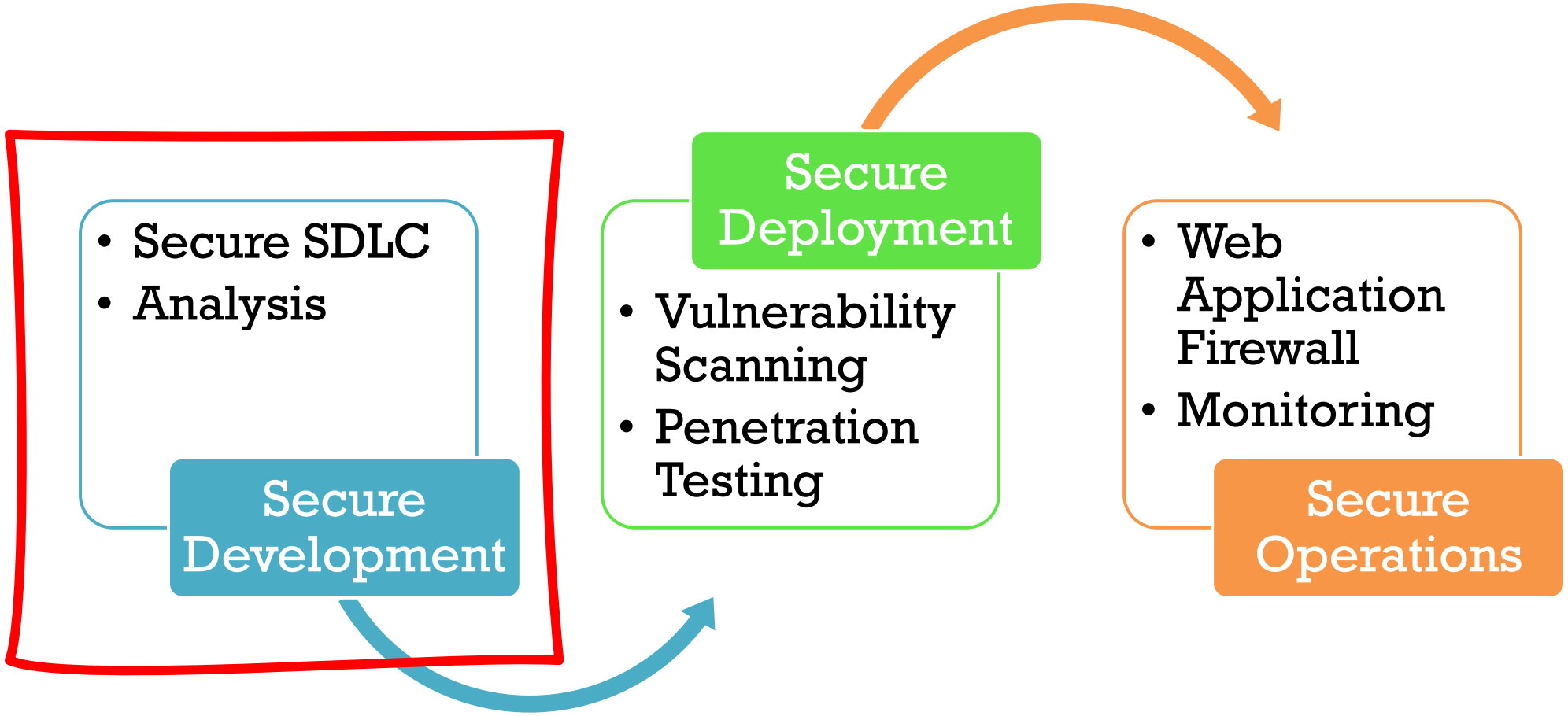
One for each functionality

WEB APPLICATION SECURITY LIFECYCLE

Web Application Security Lifecycle



Web Application Security Lifecycle



INTRODUCTION TO INFORMATION SECURITY & SECURE DEVELOPMENT

SECURE WEB DEVELOPMENT